The GRC Professional's Complete Guide to **Networking**

- OSI Model Through a GRC Lens
- Core Networking Concepts
- Network Security Controls
- GRC Domain Mapping
- Common Audit Findings and Fixes
- Network Risk Scoring
- Practitioner Checklist

All you need to know to speak the language of risk,
Ask the questions that matter.
And succeed in audit.

CONTENTS

Table of Contents

Section 1 Why GRC Professionals Need Networking Knowledge **3**

Section 2 The OSI Model, Layer by Layer, Through a GRC Lens **4**

Section 3 Core Networking Concepts for GRC **9**

Section 4 Networking Mapped to GRC Domains **12**

Section 5 Network Security Controls Reference **16**

Section 6 Common Network Audit Findings and How to Fix Them **17**

Section 7 Questions GRC Professionals Should Ask **18**

Section 8 Glossary of Networking Terms for GRC **20**

Section 9 Network Architecture Patterns for GRC **22**

Section 10 Network Risk Scoring Quick Reference **24**

Section 11 Your Networking Checklist **26**

SECTION 01

Why GRC Professionals Need Networking Knowledge

GRC professionals are not network engineers. Nobody expects you to configure a router or troubleshoot a VLAN. But if you cannot read a network diagram, ask the right questions about segmentation, or understand why a flat network is a critical finding, you will miss risks that matter. Every control framework you work with, from ISO 27001 to NIST CSF to PCI DSS, has networking controls baked into it. You cannot assess what you do not understand.

Where Networking Gaps Create Real GRC Failures

Audit: You accept "we have a firewall" as evidence without understanding whether the firewall rules are actually effective, whether default-allow policies are in place, or whether the firewall covers all network boundaries. The audit misses what matters.

Risk Assessment: You score network risks using generic descriptions because you cannot differentiate between a segmentation gap and a routing misconfiguration. The risk register becomes a box-ticking exercise.

TPRM: You send a vendor questionnaire asking "do you use encryption?" but you do not know enough to challenge their answer, ask about TLS versions, or evaluate whether their network architecture actually isolates your data.

Compliance: You map controls to a framework without understanding the technical implementation behind them. The mapping looks complete on paper but is hollow underneath.

Incident Response: A network-based incident occurs and you cannot interpret the logs, understand the attack path, or explain to the board what happened in terms they can act on.

The Standard You Need to Meet

You do not need to be a network engineer. You need to be a GRC professional who can hold a credible technical conversation, challenge weak answers, and translate network risks into business language. This guide gives you exactly that.

SECTION 02

The OSI Model, Layer by Layer, Through a GRC Lens

The OSI (Open Systems Interconnection) model is a seven-layer framework that describes how data moves across a network. For GRC professionals, each layer represents a distinct zone of risk, a set of controls, and a set of questions you should be asking. Understanding where controls sit in this model tells you what is protected, what is exposed, and where your organisation has gaps.

Layer	Name	What It Does	GRC Relevance
7	Application	User-facing services: web, email, APIs	App security, IAM, OWASP controls, API governance
6	Presentation	Data formatting, encryption, compression	Encryption standards, certificate management, data protection
5	Session	Session establishment, management, teardown	Session timeouts, authentication, access control policies
4	Transport	Reliable data delivery (TCP/UDP), port management	TLS/SSL, port security, encryption in transit
3	Network	IP addressing, routing, packet forwarding	Firewalls, segmentation, zero trust, network access control
2	Data Link	MAC addressing, frame delivery, switching	VLAN segmentation, switch security, NAC, ARP security
1	Physical	Physical transmission: cables, signals, hardware	Physical security, data centre controls, environmental risk

Layer 1: Physical

The physical layer covers the tangible infrastructure: cables, switches, wireless access points, data centre facilities, and the physical environment in which network hardware operates. For GRC, this is where physical security controls meet network infrastructure.

Key Controls and Risks

- Physical access controls to network closets, server rooms, and data centres
- Cable management and labelling (unlabelled cables mean untracked connections)
- Environmental controls: power, cooling, fire suppression for network hardware
- Rogue device detection: unauthorised devices physically connected to the network
- Site audit scope: does your physical security assessment cover network infrastructure?

GRC Questions to Ask

Who has physical access to network infrastructure? Is there a process for detecting unauthorised physical devices? Are network equipment locations included in physical security audits? Are cable runs documented and protected from tampering?

Layer 2: Data Link

The data link layer handles communication between directly connected devices using MAC addresses. This is where switches operate, VLANs segment traffic, and network access control (NAC) decides whether a device is allowed on the network at all.

Key Controls and Risks

- VLAN segmentation: separating network zones to contain breaches and enforce least privilege
- 802.1X port-based network access control: authenticating devices before granting access
- MAC address filtering and port security on switches
- ARP spoofing and MAC flooding attacks: threats at this layer that bypass higher-level controls
- Switch configuration management and hardening

GRC Questions to Ask

Is the network segmented into VLANs aligned with business functions and data sensitivity? Is 802.1X or equivalent NAC implemented? Are switch configurations hardened and change-controlled? Can a device plugged into any port automatically gain network access?

Layer 3: Network

The network layer is where IP addressing, routing, and firewalls operate. For GRC, this is the most consequential layer: it is where segmentation policies are enforced, where firewall rules determine what can talk to what, and where zero trust principles are implemented.

Key Controls and Risks

- Firewall rules and rule management (including change control and periodic review)
- Network segmentation and micro-segmentation enforcement
- IP address management (IPAM) and asset inventory alignment
- Routing security: ensuring routes cannot be manipulated to redirect traffic
- Zero trust architecture implementation at the network level

GRC Questions to Ask

When were firewall rules last reviewed? Is there a documented network segmentation policy? Can you demonstrate that sensitive systems are isolated from general-purpose networks? Is IP addressing aligned with your asset inventory? What is the process for firewall change requests?

Layer 4: Transport

The transport layer manages end-to-end communication reliability using TCP and UDP protocols. For GRC, this is where encryption in transit (TLS/SSL) operates, where port-level security controls are applied, and where you assess whether data moving between systems is protected.

Key Controls and Risks

- TLS/SSL configuration: protocol versions, cipher suites, certificate validity
- Port management: unnecessary open ports are unnecessary attack surface
- Encryption in transit requirements across all data flows
- Load balancer and proxy configurations (SSL termination points)

GRC Questions to Ask

What TLS version is enforced across all services? Are deprecated protocols (SSLv3, TLS 1.0, TLS 1.1) disabled? Are unnecessary ports closed? Where does SSL/TLS termination occur, and is data re-encrypted after that point?

Layer 5: Session

The session layer manages the establishment, maintenance, and termination of connections between applications. For GRC, this translates to session management controls, authentication handshakes, and timeout policies that directly affect access security.

Key Controls and Risks

- Session timeout policies: idle sessions left open are an access control failure
- Session hijacking risks and countermeasures
- Authentication and re-authentication requirements
- Concurrent session controls: limiting simultaneous sessions per user

GRC Questions to Ask

What are the session timeout thresholds for privileged and standard users? Are sessions invalidated on password change or role change? Is session data encrypted? Are concurrent sessions monitored and limited?

Layer 6: Presentation

The presentation layer handles data translation, encryption/decryption, and format conversion. For GRC, this is where data protection controls for data at rest and in processing are relevant, along with certificate management and data format validation.

Key Controls and Risks

- Encryption algorithm selection and key management
- Certificate lifecycle management (issuance, renewal, revocation)
- Data format validation to prevent injection and parsing attacks
- Compression vulnerabilities (e.g., CRIME, BREACH attacks)

GRC Questions to Ask

What encryption algorithms are in use and are any deprecated? Who manages the certificate lifecycle? Are certificates monitored for expiry? Is there a key management policy and is it followed?

Layer 7: Application

The application layer is where users interact with network services: web applications, email, APIs, DNS, and cloud services. For GRC, this is the most visible layer and the one most frequently targeted. It is where identity and access management, application security, and API governance controls operate.

Key Controls and Risks

• Web application firewalls (WAFs) and OWASP Top 10 controls • API security: authentication, rate limiting, input validation • Identity and access management (IAM): SSO, MFA, RBAC • Email security: SPF, DKIM, DMARC, anti-phishing controls • DNS security: DNSSEC, DNS filtering, protection against DNS-based attacks

GRC Questions to Ask

Is a WAF deployed in front of public-facing applications? Are APIs inventoried, authenticated, and rate-limited? Is MFA enforced for all privileged and remote access? Are email authentication records (SPF, DKIM, DMARC) configured and monitored?

SECTION 03

Core Networking Concepts for GRC

Beyond the OSI model, there are networking concepts you will encounter repeatedly in audits, risk assessments, vendor reviews, and compliance work. This section covers each one: what it is, why it matters to GRC, and what you need to know to do your job credibly.

IP Addressing and Subnetting

Every device on a network has an IP address. Subnetting divides a network into smaller segments. For GRC, IP addressing matters because it underpins asset inventory accuracy, network segmentation policies, and audit scoping. If you cannot verify that an asset inventory matches actual IP allocations, your risk assessment is built on assumptions.

- Private vs public IP ranges: know which ranges are internal (10.x.x.x, 172.16-31.x.x, 192.168.x.x) and which indicate internet exposure
- Subnet boundaries: subnets define trust boundaries. Different subnets for different sensitivity levels is a core segmentation control
- Asset inventory alignment: does the CMDB match the actual IP address allocations on the network?

DNS (Domain Name System)

DNS translates domain names to IP addresses. It is a critical piece of infrastructure and a common attack vector. DNS poisoning, typosquatting, and DNS tunnelling are real threats that GRC professionals need to understand.

- DNS filtering: used as a security control to block access to known malicious domains
- DNSSEC: cryptographic signing of DNS records to prevent tampering
- DNS logging: DNS query logs are a valuable data source for incident detection and investigation
- DNS-based attacks: DNS cache poisoning, DNS tunnelling for data exfiltration, and typosquatting

DHCP (Dynamic Host Configuration Protocol)

DHCP automatically assigns IP addresses to devices when they join a network. The GRC risk: rogue DHCP servers can redirect traffic, assign malicious DNS servers, or bring unregistered devices onto the network without detection.

- DHCP snooping: a switch-level control that filters untrusted DHCP messages

- Rogue DHCP detection: part of network monitoring and incident response
- IP allocation records: DHCP logs support asset tracking and forensic investigation

VPNs and Tunnelling

VPNs create encrypted tunnels for remote access. For GRC, VPN configuration directly affects remote work security, data protection, and compliance with access control requirements.

- Split tunnelling risk: if enabled, user traffic bypasses corporate security controls while connected to the VPN
- VPN authentication: MFA on VPN access is a baseline control for most frameworks
- Logging and monitoring: VPN connection logs are essential for access reviews and incident investigation

Firewalls

Firewalls are the most referenced network control in GRC. But "we have a firewall" is not a control statement. The effectiveness of a firewall depends entirely on its rules, its placement, and the discipline of its management.

- Types: packet filtering, stateful inspection, next-generation (NGFW), web application firewalls (WAFs)
- Rule management: who can create rules, how are changes approved, how often are rules reviewed?
- Default-deny vs default-allow: the single most important firewall policy question
- Rule sprawl: unused, overlapping, or overly permissive rules degrade firewall effectiveness over time

Network Segmentation and Micro-Segmentation

Segmentation divides a network into isolated zones. Micro-segmentation takes this further, applying granular policies down to individual workloads. For GRC, segmentation is a foundational control that limits blast radius, enforces least privilege at the network level, and is required or recommended by virtually every framework.

- Flat networks: a network with no segmentation is a critical audit finding in any framework
- Zone-based architecture: DMZ, internal, management, and sensitive data zones
- PCI DSS CDE isolation: cardholder data environment must be segmented from the rest of the network
- Micro-segmentation in cloud: security groups and network policies in AWS, Azure, GCP

Wireless Networking

Wireless networks extend the attack surface beyond physical boundaries. For GRC, wireless security policies, rogue access point detection, and encryption standards are common audit and risk assessment items.

- WPA3: the current standard. WPA2 is acceptable with strong passphrases; WEP is a critical finding
- Guest networks: must be isolated from corporate networks with no route to internal resources
- Rogue AP detection: wireless intrusion detection/prevention systems (WIDS/WIPS)
- BYOD policies: personal devices on corporate wireless require clear policy and technical controls

Cloud Networking Basics

Cloud environments have their own networking constructs that GRC professionals must understand to assess cloud-hosted systems and review cloud security architectures.

- VPC (Virtual Private Cloud): an isolated network environment within a cloud provider
- Security groups and NACLs: cloud-native firewalls controlling inbound/outbound traffic
- Hybrid connectivity: VPN and direct connect links between on-premises and cloud networks
- Shared responsibility model: the cloud provider secures the network infrastructure; you secure your configuration
- Cloud network logging: VPC flow logs, CloudTrail, Azure NSG flow logs for monitoring and forensics

Network Monitoring and Logging

You cannot govern,assess risk,or respond to incidents without visibility into what is happening on the network. Monitoring and logging are not just IT operations concerns; they are core GRC controls.

- SIEM integration: network logs feeding into a Security Information and Event Management platform
- NetFlow/sFlow: metadata about network traffic patterns, useful for anomaly detection
- Packet capture: full network traffic capture for forensic investigation
- Log retention: regulatory and framework requirements for how long logs must be kept
- Alerting: real-time alerts for policy violations, unusual traffic patterns, and known attack signatures

SECTION 04

Networking Mapped to GRC Domains

This section maps networking concepts directly to the GRC domains you work in every day. Each domain has specific networking touchpoints, and understanding them makes your work sharper, more credible, and more effective.

Governance

Network governance ensures that network architecture decisions are aligned with business objectives, risk appetite, and regulatory requirements. It covers the policies, roles, and decision-making structures that control how the network is designed, operated, and changed.

Governance Area	Networking Relevance
Network Architecture Policy	Defines segmentation requirements, zone classifications, and acceptable network topologies
Roles and Responsibilities	Who approves firewall changes? Who owns network risk? Who reviews network access?
Change Management	Network changes (firewall rules, routing, segmentation) must follow change control processes
Standards and Baselines	Hardening standards for switches, routers, firewalls, wireless APs, and cloud network components
Board Reporting	Network risk metrics, segmentation posture, and critical network incidents reported to leadership

Risk Management

Network-based risks are among the most consequential in any risk register. Understanding networking allows you to identify, assess, and articulate these risks with precision rather than generic descriptions.

Risk Scenario	Network Concept	Impact
Flat network allows lateral movement	Segmentation	A single compromised host can reach every system
Unpatched network device exploited	Firmware management	Network infrastructure itself becomes the attack vector
VPN split tunnelling enabled	VPN configuration	Corporate traffic bypasses security controls

Risk Scenario	Network Concept	Impact
Default firewall rules not changed	Firewall management	Overly permissive access negates firewall investment
No DNS filtering	DNS security	Users can reach known malicious domains without restriction
Cloud security groups misconfigured	Cloud networking	Cloud resources exposed to the internet unintentionally

Compliance

Every major compliance framework includes networking controls. This table maps key network controls to the frameworks you are most likely working with.

Network Control	ISO 27001	NIST CSF	PCI DSS	SOC 2
Network segmentation	A.8.22	PR.AC-5	Req 1.3	CC6.1
Firewall management	A.8.20, A.8.21	PR.PT-4	Req 1.1-1.2	CC6.1, CC6.6
Encryption in transit	A.8.24	PR.DS-2	Req 4.1	CC6.1, CC6.7
Access control (network)	A.8.20	PR.AC-3	Req 7.1	CC6.1, CC6.3
Logging and monitoring	A.8.15, A.8.16	DE.CM-1	Req 10.1-10.7	CC7.2
Wireless security	A.8.20	PR.AC-3	Req 1.3, 2.1.1	CC6.1
Change management	A.8.32	PR.IP-3	Req 6.4	CC8.1

Audit

Network auditing requires understanding what to ask for, what to look at, and what constitutes a finding versus a risk acceptance.

- Evidence to request: network diagrams, firewall rule sets, VLAN configurations, change management logs, vulnerability scan results, wireless survey reports
- What to verify: segmentation is implemented as documented, firewall rules match policy, logging is active and retained, hardening baselines are applied
- Common gaps: network diagrams out of date, no periodic firewall rule review, flat network with no segmentation, default credentials on network devices
- Testing techniques: review firewall configurations, verify segmentation with traffic flow analysis, check patch levels on network devices, validate logging coverage

Third-Party Risk Management (TPRM)

When assessing vendors and third parties, network security is a core evaluation domain.

Assessment Area	What to Evaluate
Vendor network architecture	Is the vendor's network segmented? Is your data isolated from other customers?
Connectivity to your network	How does the vendor connect? VPN, API, direct link? What controls are on that connection?
Encryption standards	What encryption is used in transit and at rest? What TLS versions? What cipher suites?
Monitoring and incident response	Does the vendor monitor its network? What is its mean time to detect? Will it notify you of network incidents?
Cloud infrastructure	If cloud-hosted: which provider, what region, what network controls (security groups, VPC, NACLs)?
SLA and uptime	What are the network availability SLAs? What is the redundancy architecture?

Policy

Network-related policies form the foundation of network governance. Without clear, enforceable policies, network controls are ad hoc and inconsistent.

Policy	What It Covers
Network Security Policy	Segmentation requirements, access control principles, encryption standards, monitoring obligations
Firewall Management Policy	Rule creation/approval process, periodic review cadence, default-deny requirement, documentation standards
Remote Access Policy	VPN requirements, MFA enforcement, split tunnelling prohibition, device compliance checks
Wireless Security Policy	Approved encryption standards, guest network isolation, rogue AP detection, BYOD controls
Acceptable Use Policy	Network usage expectations, prohibited activities, monitoring notice, consequences of violation
Incident Response (Network)	Network-specific detection, containment, and evidence preservation procedures

Incident Response

Network-based incidents are among the most common and most consequential. GRC professionals need to understand the network dimensions of incident detection, containment, and forensics.

Detection

- IDS/IPS alerts from network sensors
- SIEM correlation of network log events
- NetFlow anomalies indicating unusual traffic patterns or data exfiltration
- DNS query anomalies (high volume, unusual domains, DNS tunnelling indicators)

Containment

- Network isolation of affected segments or hosts
- Firewall rule changes to block attacker IPs or command-and-control communications
- VLAN quarantine for compromised devices
- VPN session termination for compromised accounts

Forensic Evidence from Network Sources

- Firewall and proxy logs showing connection history
- Packet captures preserving actual network traffic
- DNS logs showing resolution requests
- DHCP logs mapping IP addresses to devices at specific times
- VPN logs showing remote access sessions

SECTION 05

Network Security Controls Reference

A quick-reference table of essential network security controls. Each entry shows what the control does, where it sits in the OSI model, which frameworks reference it, and which GRC domain it serves.

Control	OSI Layer	Frameworks	GRC Domain
Firewall (NGFW)	Layer 3-7	ISO 27001, NIST, PCI, SOC 2	Risk, Compliance, Audit
Network Segmentation	Layer 2-3	ISO 27001, NIST, PCI DSS	Governance, Risk, Compliance
IDS/IPS	Layer 3-7	NIST CSF, PCI DSS, SOC 2	Risk, Incident Response
VPN (Remote Access)	Layer 3-4	ISO 27001, NIST, SOC 2	Policy, Compliance, TPRM
NAC (802.1X)	Layer 2	ISO 27001, NIST CSF	Governance, Compliance, Audit
WAF	Layer 7	OWASP, PCI DSS, NIST	Compliance, Risk, Audit
DNS Filtering	Layer 7	NIST CSF, CIS Controls	Risk, Policy
TLS/SSL Encryption	Layer 4-6	ISO 27001, PCI DSS, GDPR	Compliance, TPRM, Risk
SIEM (Network Logs)	Layer 3-7	ISO 27001, NIST, SOC 2	Audit, Incident Response
DLP (Network)	Layer 7	ISO 27001, GDPR, NIST	Compliance, Risk, Policy
Wireless Security	Layer 1-2	PCI DSS, NIST, CIS	Compliance, Audit, Policy
Micro-Segmentation	Layer 3-4	NIST ZTA, CIS Controls	Risk, Governance
Packet Capture	Layer 2-3	ISO 27001, NIST	Incident Response, Audit
Network Monitoring	Layer 3-7	ISO 27001, NIST, SOC 2	Risk, Audit, IR

SECTION 06

Common Network Audit Findings

These are the network-related findings GRC professionals encounter most frequently. For each finding, the table shows the risk, the typical root cause, and the recommended remediation.

Finding	Risk	Root Cause	Remediation
Flat network, no segmentation	Lateral movement across all systems	Network grew organically without architecture review	Implement VLAN segmentation based on data classification and function
Default credentials on network devices	Unauthenticated administrative access	Devices deployed without hardening	Enforce hardening baselines for all network devices before deployment
No current network diagram	Cannot verify scope, boundaries, or controls	Diagrams not maintained through changes	Mandate network diagram updates as part of change management
Firewall rule sprawl	Overly permissive access, shadow rules	No periodic rule review process	Implement quarterly firewall rule reviews with business justification required
Unpatched network device firmware	Known vulnerability exploitation	No patching schedule for infrastructure	Include network devices in vulnerability management programme
Excessive open ports	Unnecessary attack surface	Ports opened for projects and never closed	Implement port justification process and periodic scanning
No network logging or inadequate retention	Cannot detect or investigate incidents	Logging not configured or storage limits hit	Define logging requirements per framework, monitor log pipeline health
Guest WiFi not isolated	Guest devices can reach internal resources	Guest network shares infrastructure with corporate	Isolate guest wireless on separate VLAN with no internal routing

SECTION 07

Questions GRC Professionals Should Ask

The right question, asked to the right person, at the right time, is the most powerful tool in a GRC professional's toolkit. These questions are organised by who you are talking to and what you are trying to achieve.

Questions for IT and Network Teams

- Can you show me a current, accurate network diagram including all network zones and boundaries?
- What is the network segmentation strategy and how does it align with data classification?
- When were firewall rules last reviewed and by whom? How many rules are currently active?
- Is the default firewall policy deny-all or allow-all?
- What network monitoring tools are in place and what do they cover?
- How are network changes approved, documented, and tested before implementation?
- What is the patch cycle for network infrastructure (routers, switches, firewalls, APs)?
- Are there any known network segments or devices that are not covered by current security controls?

Questions for Vendors and Third Parties

- How is our data isolated from other customers at the network level?
- What encryption is used for data in transit between our systems and yours? What TLS version?
- Can you provide evidence of network penetration testing conducted in the last 12 months?
- How would you detect and contain a network breach that affects our data?
- What are the network availability SLAs and what is the redundancy architecture?
- If you use cloud infrastructure, which provider, which region, and what network controls are in place?

Questions for Board and Executive Reporting

- What is our current network segmentation maturity and how does it compare to our risk appetite?
- How many critical or high-severity network vulnerabilities are currently unpatched, and what is the trend?
- What is our mean time to detect a network-based security incident?
- Are there network architecture decisions that require investment or executive approval?
- How does our network security posture affect our compliance status across active frameworks?

Questions for Audit Scoping

- Which network zones and boundaries are in scope for this audit?
- Are there any network changes planned or recently completed that affect the audit scope?
- What network evidence (diagrams, configs, logs, scan results) is available and current?
- Have previous network audit findings been remediated and can evidence be provided?
- Are there network components managed by third parties that are within scope?

SECTION 08

Glossary of Networking Terms for GRC

Every term defined in the context GRC professionals encounter it, not textbook definitions.

Term	GRC-Relevant Definition
ARP	Address Resolution Protocol. Maps IP addresses to MAC addresses. ARP spoofing is a Layer 2 attack vector.
BGP	Border Gateway Protocol. Routes traffic between networks. BGP hijacking can redirect internet traffic, a supply chain risk.
CIDR	Classless Inter-Domain Routing. Notation for IP address ranges (e.g., 10.0.0.0/24). Used in firewall rules and segmentation.
DHCP	Dynamic Host Configuration Protocol. Auto-assigns IPs. Rogue DHCP servers are a detection and access control risk.
DMZ	Demilitarised Zone. A network segment between external and internal networks for public-facing services.
DNS	Domain Name System. Translates names to IPs. DNS logs are audit evidence; DNS filtering is a security control.
DNSSEC	DNS Security Extensions. Cryptographic DNS signing. Prevents DNS cache poisoning and tampering.
Firewall	Network access control device enforcing traffic rules. Effectiveness depends on rule quality and review cadence.
IDS/IPS	Intrusion Detection/Prevention System. Monitors (IDS) or blocks (IPS) malicious network traffic.
IP Address	Unique network identifier. Private ranges (10.x, 172.16-31.x, 192.168.x) indicate internal; public IPs indicate exposure.
MAC Address	Hardware address for network interfaces. Used in NAC and port security. Can be spoofed.
Micro-Segmentation	Granular network segmentation at workload level. Core to zero trust architectures.
MFA	Multi-Factor Authentication. Required for network access (VPN, admin interfaces) in virtually all frameworks.
NAC	Network Access Control. Verifies device identity and compliance before granting network access.
NAT	Network Address Translation. Maps internal IPs to external. Hides internal network structure from outside.

Term	GRC-Relevant Definition
NetFlow	Network traffic metadata. Shows who talked to whom, when, how much. Used in anomaly detection and forensics.
NGFW	Next-Generation Firewall. Combines traditional firewall with application awareness, IPS, and threat intelligence.
NTP	Network Time Protocol. Ensures consistent timestamps across devices. Critical for log correlation and forensics.
Packet	Unit of data transmitted over a network. Packet capture is a forensic evidence source.
Port	Logical endpoint for communication. Well-known ports: 80 (HTTP), 443 (HTTPS), 22 (SSH), 3389 (RDP).
Proxy	Intermediary server for network requests. Used for filtering, logging, and enforcing web access policies.
SIEM	Security Information and Event Management. Aggregates and correlates logs including network events.
SNMP	Simple Network Management Protocol. Manages network devices. SNMPv1/v2 transmit in cleartext, a known risk.
Subnet	A subdivision of a network. Defines broadcast domains and trust boundaries for segmentation.
TLS/SSL	Transport Layer Security/Secure Sockets Layer. Encrypts data in transit. Version and cipher suite matter.
VLAN	Virtual LAN. Logically segments a physical network. Core segmentation control at Layer 2.
VPC	Virtual Private Cloud. Isolated cloud network. Equivalent of a segmented network in cloud environments.
VPN	Virtual Private Network. Encrypted tunnel for remote access. MFA and split-tunnelling policies are key controls.
WAF	Web Application Firewall. Filters HTTP/HTTPS traffic. Protects against OWASP Top 10 attacks at Layer 7.
Zero Trust	Security model: never trust, always verify. Applied at network level through micro-segmentation and identity-aware access.

SECTION 09

Network Architecture Patterns for GRC

Understanding common network architecture patterns helps GRC professionals assess whether an organisation's network design is fit for purpose. These are the patterns you will encounter most frequently in audits, risk assessments, and vendor reviews.

Flat Network

A single network segment with no logical separation between systems. Every device can communicate directly with every other device. This is the most dangerous architecture from a GRC perspective and is a critical finding in every framework.

- GRC Impact: no containment capability, maximum blast radius from any single compromise, violates least privilege at the network level
- Common in: small organisations that grew without network planning, legacy environments
- Remediation priority: critical. Segmentation is a foundational control

Zone-Based Architecture

The network is divided into zones based on trust level and function: DMZ for public-facing services, internal zone for corporate systems, management zone for administrative access, and a sensitive data zone for high-value assets. Traffic between zones passes through firewalls with explicit rules.

- GRC Impact: clear trust boundaries, enforceable access policies, auditable traffic flows between zones
- Common in: mid-size to large organisations, PCI DSS compliant environments
- Key question: are the zone boundaries documented and are the inter-zone rules reviewed periodically?

Zero Trust Architecture

No implicit trust based on network location. Every access request is authenticated, authorised, and encrypted regardless of whether the request comes from inside or outside the network perimeter. Identity becomes the new perimeter.

- GRC Impact: strongest security posture, aligns with NIST SP 800-207, reduces reliance on perimeter controls
- Common in: mature organisations, cloud-first environments, government and defence
- Key question: is zero trust implemented at the network layer (micro-segmentation) or only at the identity layer (SSO/MFA)?

Hub and Spoke

Branch offices connect to a central hub (headquarters or data centre) through VPN or MPLS links. All inter-branch traffic routes through the hub. Common in distributed organisations.

- GRC Impact: centralised security controls at the hub, but single point of failure. Branch security depends on hub availability
- Key question: what happens to branch office security if the hub link goes down? Is there local breakout?

Cloud-Native and Hybrid Architectures

Workloads split between on-premises data centres and cloud providers. Network connectivity via VPN, direct connect, or SD-WAN. Security controls must span both environments consistently.

- GRC Impact: shared responsibility gaps, inconsistent policy enforcement across environments, complex audit scope
- Key question: are network security policies consistently applied across on-premises and cloud environments?

Architecture Assessment Tip

When reviewing network architecture, always ask: "Show me the network diagram." If one does not exist or is more than six months old, that is your first finding. You cannot assess what is not documented.

SECTION 10

Network Risk Scoring Quick Reference

When scoring network-related risks for your risk register, use this reference to calibrate severity consistently. The ratings below reflect typical scoring for an organisation with standard risk appetite. Adjust based on your organisation's context, industry, and regulatory obligations.

Network Risk	Severity	Rationale
Flat network, no segmentation	CRITICAL	Maximum blast radius. Lateral movement unrestricted. Violates every framework.
Default credentials on network devices	CRITICAL	Direct administrative access to infrastructure. Trivially exploitable.
No network logging	HIGH	Cannot detect incidents or support forensic investigation. Compliance failure.
Outdated network diagram	HIGH	Cannot verify scope, boundaries, or control placement. Audit blocker.
Firewall rule sprawl (no review)	HIGH	Overly permissive rules accumulate. Effective security degrades over time.
Unpatched network firmware	HIGH	Known vulnerabilities in infrastructure devices. Actively targeted by attackers.
Split tunnelling on VPN	MEDIUM	Remote users bypass corporate security controls. Data leakage risk.
Guest WiFi not isolated	MEDIUM	Guest devices can potentially reach internal resources. Segmentation failure.
No DNSSEC	MEDIUM	DNS responses can be spoofed. Lower likelihood but high impact if exploited.
SNMP v1/v2 in use	MEDIUM	Community strings sent in cleartext. Network device credentials exposed.
No network change documentation	MEDIUM	Cannot verify what changed, when, or why. Audit finding.
NTP not synchronised	LOW	Inconsistent timestamps complicate log correlation and forensic analysis.

Scoring Discipline

The most common mistake in network risk scoring is treating everything as "medium" because the assessor does not understand the technical impact. A flat network is not a medium risk. Default credentials on a core switch are not a medium risk. If you understand the networking concept, you can score the risk accurately. That is what this guide is for.

SECTION 11

Your Networking Checklist

A practical checklist for GRC professionals to use when conducting network-related assessments, audits, or vendor reviews. Use each item as a prompt: can we demonstrate this?

Documentation and Governance

- ☐ Current network diagram exists and is dated within the last 6 months
- ☐ Network security policy is approved, current, and communicated
- ☐ Roles and responsibilities for network security are defined
- ☐ Network change management process is documented and followed
- ☐ Hardening baselines exist for all network device types
- ☐ Network architecture decisions are aligned with business risk appetite
- ☐ Network asset inventory is maintained and reconciled with CMDB

Segmentation and Access Control

- ☐ Network is segmented into zones aligned with data classification
- ☐ Firewall rules enforce default-deny between zones
- ☐ Firewall rules are reviewed at least quarterly
- ☐ 802.1X or equivalent NAC is implemented
- ☐ Guest wireless is isolated from corporate network
- ☐ VPN access requires MFA
- ☐ Split tunnelling is disabled on corporate VPN
- ☐ Administrative access to network devices uses a dedicated management VLAN
- ☐ Unused switch ports are disabled or assigned to a quarantine VLAN

Encryption and Protocols

- ☐ TLS 1.2 or higher enforced on all services
- ☐ Deprecated protocols (SSLv3, TLS 1.0, TLS 1.1) are disabled
- ☐ SNMP v3 is used (v1/v2 disabled)
- ☐ Certificates are inventoried and monitored for expiry
- ☐ DNS security (DNSSEC, DNS filtering) is implemented
- ☐ Key management policy exists and encryption keys are rotated on schedule
- ☐ Email authentication (SPF, DKIM, DMARC) is configured and monitored

Monitoring, Logging, and Incident Response

- ☐ Network logs are collected and fed into SIEM
- ☐ Log retention meets regulatory and framework requirements
- ☐ IDS/IPS is deployed at network boundaries
- ☐ Alerting is configured for policy violations and anomalies
- ☐ Network incident response procedures are documented and tested
- ☐ Packet capture capability exists for forensic investigation
- ☐ NTP is synchronised across all network devices for consistent timestamps
- ☐ Network-based incident scenarios are included in tabletop exercises

Vulnerability and Patch Management

- ☐ Network devices are included in vulnerability scanning scope
- ☐ Firmware patching schedule exists and is followed
- ☐ Default credentials are changed on all network devices
- ☐ Unnecessary services and ports are disabled
- ☐ Network penetration testing is conducted at least annually
- ☐ Vulnerability remediation SLAs are defined and tracked for network assets

Cloud and Third-Party

- ☐ Cloud security groups and NACLs are reviewed periodically
- ☐ VPC flow logs are enabled and monitored
- ☐ Third-party network connections are documented and controlled
- ☐ Vendor network security is assessed as part of TPRM
- ☐ Shared responsibility boundaries are documented for each cloud provider
- ☐ Cloud-to-on-premises connectivity uses encrypted tunnels with MFA
- ☐ API gateways are secured with authentication, rate limiting, and logging

Physical and Environmental

- ☐ Network closets and server rooms have access controls and logging Cabling is
- ☐ labelled, documented, and protected from physical tampering Environmental
- ☐ controls (power, cooling, fire suppression) protect network hardware Rogue device
- ☐ detection is in place for both wired and wireless networks Physical network
- ☐ infrastructure is included in disaster recovery planning

How to Use This Checklist

This is not a compliance checkbox. It is a conversation starter. For each item, ask: "Can we demonstrate this?" If the answer is no, that is a gap. If the answer is "we think so but cannot prove it," that is also a gap. Evidence matters.